Name : AKASH SAMPATH

Title : Research_Q_A_Part_3

Authentication & Authorization:

Q1 . What is authentication?

- Authentication is the process of verifying who someone is and like showing a digital ID to secure guard to prove who you are
- It is the first step in security where before a system can give you access to your data , it must confirm your identity by answering the questions “Are you really akash?”
- We can verify our identity by logging in

Q2. What are the different types of authentication?

Most systems use one or more of these types to prove identity and most used type is MFA known as Multi Factor Authentication which is the most secure

Something You Know :

- Based on what knowledge we have and the most common type of authentication and relies on the information that only user should have in their mind
- Passwords , PIN , Security Questions or pattern swipes are the examples

Something You Have :

- Based on what we possess where it requires the user to physically possess a specific object
- Like physical key , smart card or OTP known as One Time Password where sends to your mobile phone , these are the examples

Something You are :

- Based on our biological traits which are unique to the individual known as Biometrics
- Fingerprint scans , Face ID , Eye scan or voice password are the examples

Some methods using in Authentication :

Single Factor Authentication :

- Known as SFA and the only method is used like just password and it is least secure

Two Factor Authentication :

- Known as 2FA which requires two different factors like both a password and code sent to your phone

Multi Factor Authentication :

- Known as MFA which uses two more layers of security

Single Sign On :

- A method allows a user to login in once and gain access to multiple systems like using Google account to access websites or applications

Biometric Authentication :

- Using physical characteristics to grant access

Real World Examples : Authentication Method :

Scenarios :

- Withdrawing Cash by inserting Debit card which we have and entering a PIN we know
- Unlocking an iPhone using scanned face ID
- Logging into Gmail by entering your password which you know and tapping yes on your phone notification which you have

Q3. What is authorization?

- It is the process of determining what a person is allowed to do once they are inside a system
- A set of permissions that determines which room you can enter and whether you can move the furniture

Some Concepts of Authorization :

Permissions and Rules :

- Set of rules defined by the admin that grants or denies access to specific resources like files , databases or features

Happens After Login :

- Authorization always occurs after a user has successfully proven who they are

The What Questions :

- Have to answer the question like “What is this user allowed to do ?”

Least Privilege :

- A common security goal where users are only given minimum permissions to what they can access equal to their jobs

Real Life Examples : Authorization :

The Hotel :

- Your key card is programmed to open your room and it will not open other guest rooms or manager office

Q4. What are the different types of authorization?

Role Based Access Control (RBAC) :

- It is common method and access is granted based on user's job function or title within an organization rather than their individual identity
- Permissions are assigned to roles and users are assigned to those roles
- Clearly define job duties from a structured organizations
- In a blog system an editor can delete any post , while an author can only delete their own posts which this is an example

Attribute Based Access Control (ABAC) :

- This a more flexible approach that uses characteristics to make decisions in real time

This looks at four factors :

Subject :

- Who is the user and must be over 18 years of age !

Resource :

- What are they accessing whether only secret documents ?

Action :

- What are they doing like only reading ?

Environment :

- Where or When like only during office hours from a company point of view

Example :

- A manager can only view financial reports if they are accessing them from the office building between 9: AM and 5:PM

Discretionary Access Control (DAC) :

- It is a user based model where the owner of the data decides who gets access
- The person who created the file or resource has total control over its permissions can pass those permissions to others
- Best for social media , personal file sharing and small collaboration

Example :

- Google Docs where you own the document and you choose exactly which email addresses can view or edit it

Mandatory Access Control (MAC) :

- The strictest form of authorization usually managed by a central authority like a system admin
- Users are given a secret unclassified top secret data which given as a classification where users cannot change permissions on their own and the system enforces the rules
- Best for Military , Government or high security corporate environments

Example :

- A solider with secret documents or data cannot open a file labelled as Top Secret even if they are the one who wrote the report

Relationship Based Access Control (RBAC) :

- Grants access based on relationship between a user and a resource
- Uses connection like if you are friends with someone or part of the same folder you get access

Example :

- On Facebook you can only see a photo if you are friends with the uploaded or Friends of Friends

Q5.How does authentication differ from authorization?

- Authentication is about identity and Authorization is about permissions

Authentication :

- Asks "Are you who you say you are ?"
- Process of verifying a user's identity and it is the first step in any security process
- Before a system can decide what you are allowed to know by what your are actually
- Uses to prove identity and this happens at the start such as login screen

Authorization :

- Asks "What are you allowed to do ? "
- Happens after successfully authenticated and process of checking what files , data or settings you have permission to access
- Actually controls access and permissions
- Happens after login every time you try to perform an action

Real World Comparison :

Imagine you are visiting a large corporate office building :

In Step 1 :

- Authentication process happens like showing our photo ID to the receptionist and they confirm that you are the person on the ID card

In Step 2 :

- Authorization process happens where receptionist gives you a keycard if it lets you into the lobby and the Cafeteria but won't let you into the CEO office or the Server Room

Therefore ,

- Authentication always comes first and Authorization follows
- Cant transfer your identity (Authentication) but your permissions (Authorization) can be changed by an admin at any time without you re logging in

---

Serialization & Deserialization :

Q1. What is serialization?

- Serialization actually means converting an object or data into a format that can be stored or sent
- The converted format is usually JSON , XML , Binary and String
- This allows data to be saved to a file and sent over a network and stored in a database and are shared between different systems
- In simple words serialization makes an object a transferable format

Some Concepts : Serialization :

- The object is actually a live data sitting in your computer RAM while the program is running in python dictionary or java object
- The stream which is the serialized version where a flat string of bytes or text like JSON or XML can live on the hard drive or travel across the internet
- This helps to save the state of an object so does not disappear when the program is turned off

Q2. What is deserialization?

- It is actually the reverse of serialization where it converts stored or transferred format back into the object like JSON to object
- And it is process of taking a formatted data stream like a string of text or a sequence of bytes and turning it back into a live object that a program can use
- It actually helps to allow programs to remember data that was saved to a file or sent over the internet
  In this data is stored in formats like JSON , XML or Binary before is deserialized
- Once a piece of data is deserialized the computer can gain access its properties and run its functions

The big picture : Serialization and Deserialization :

Imagine having a picture drawing which is so complex and want to send this drawing for your friend across the internet via chat

- First we take the drawing online and we keep the complex drawing procedure in order pieces and this is called serialization
- Our friend receives the complex drawing and uses the exact procedure to draw again the complex drawing and this is called deserialization

Q3. Why are serialization and deserialization important in APIs?

- For API content our data needs to travel between two different systems like a mobile app and a server and these systems often speak different programming languages so it needs a universal way to pack data for the journey
- A server might be written in Java but the phone app is written in python so serialization acts as a common language that both can understand
- It ensures that the structure of the data remains the same and if you send a user profile , serialization ensures the name , email and age don't get mixed up during the transfer
- If we want to save user's session or a game state to a database , you must serialize it into a format the database can hold
- Modern serialization methods can make data lighter allowing API responses to load faster on slow internet connections
- Deserialization turns back text into a live object that the code can interact like adding a price by changing its status
- When we deserialize the data the systems often checks if the data is legal like if the API expects a number for price but receives the word free , This process will catch the error before it breaks your database
- In deserialization rebuilds that complex hierarchy so the server knows exactly which items belong to which customer like sending a shopping cart that contains a list of items

Q4. Can you give examples of serialization formats?

JSON :

- It is known as JavaScript Object Notation and the most popular where it is human readable with text based and used in API and web apps and it is easy to learn and debug and its lightweight

XML :

- Known as Extensible Markup Language which is also text based and uses tags like HTML and longer than JSON and older but still used in enterprise systems
- It is human readable and large in size and speed is medium

YAML :

- This is human friendly and very clean and readable with no backets needed which is used for configuration
- Used in Kubernetes and docker compose and DevOps configs
- Its size is medium and also speed is medium

CSV :

- Known as Comma Separated Values
- It is in simple table format with each row and record and values separated by commas and its very light weight
- It is used in excel data , reports and data importing and exporting
- It is human readable and small size and very fast

Examples :

JSON :

```
{
  "name": "Akash",
  "age": 25,
  "skills": ["AWS", "Docker"]
}
```

XML :

```
<user>
  <name>Akash</name>
  <age>25</age>
  <skills>AWS</skills>
</user>
```

YAML :

```
name: Akash
age: 25
skills:
  - AWS
  - Docker
```

CSV :

```
name,age,skill
Akash,25,AWS
Ravi,30,Docker
```

JSON & XML (HTTP Responses) :

Q1. What is JSON format?

- Known as JavaScript Object Notation , this is simple and text based way to store and share data between computers and applications
- Even through JavaScript is the name , it is language independent where it can be used with almost any programming language like Python , Java , PHP
- This uses a specific way of writing text so that both humans and computers can easily read and the data is organized into keys as labels and values as the actual data separated by a colon
- Most modern websites and apps use JSON to send information back and forth between a server and your web browser
- Curly Braces { } hold a collection of data
- Square Brackets [ ] hold list of items
- Double Quotes “ “ are required for all keys and text values
- Commas , a separates different pieces of data in the same list

Example : JSON

```
{
  "name": "Jane Doe",
  "age": 28,
  "is_subscriber": true,
  "hobbies": ["reading", "hiking", "coding"],
  "location": {
    "city": "New York",
    "zip": "10001"
  }
}
```

Explanation : Above : Code :

- “name” is a key and Jane Doe is its value
- “hobbies” contains a list of strings
- “location” is nested object showing that JSON can hold complex structures
- Values can be String , Number , Boolean (true / false), Array , Object , Null

Example : JSON with different data types :

```
{
  "name": "Akash",
  "age": 25,
  "isStudent": false,
  "skills": ["AWS", "Linux", "DevOps"],
  "address": {
    "city": "Hyderabad",
    "pincode": 500001
  }
}
```

Here , We can see :

- **String :** “Akash”
- **Number :** 25
- **Boolean :** false
- **Array :** ["AWS","Linux","DevOps"]
- **Object :** address { } inside other object

Q2. What is XML format?

- Known as Extensible Markup Language is a text based format designed to store and transport data and looks similar to HTML and purpose is to describe what data is rather than how it should look on screen
- Unlike HTML , which has fixed tags like <h1> , XML lets you invent your own tags like <price> or <author > to suit our specific data
- Both humans and machines can easily understand the file content because the tags explains the data
- The data is organized in a tree format with a single root element at the top which contains all other elements like Hierarchical Structure
- XML is case sensitive and requires every opening tag like <item> to have a matching closing tag like </item>

- This works across all operating system and programming languages making it a universal translator for sharing data between different systems

Q3. How is JSON used in HTTP responses?

- JSON is a light weight text format used to send data from the server to a client like browser or mobile app in an HTTP response
- It is easy to read and write and its light weighted for faster transfer and is supported by almost all programming languages and is perfect for API and web applications and easy for frontend apps to use

Working :

- Client sends HTTP request by getting user data and server processes the request and server sends back an HTTP response and the response body contains JSON data and finally clients reads and uses the JSON data

Simple Real Life :

- The food your order is the HTTP request and the restaurant is the server and food package with labelled items is the JSON response and when we open and use it , it is the client app

Q4. How is XML used in HTTP responses?

- XML is a format used to send structured data and a server can send data to a client such as browser or app in XML format using an HTTP Response
- Commonly used in Web services and API and system to system communication
- XML is used in HTTP responses to send structured data and it is easy for different systems to read and check and its language independent which works for all programming languages
- Uses tags to clearly define data meaning and is good for complex hierarchical data

Working :

- Client sends HTTP request and asks for data and server processes the request and server sends HTTP response and response body containing XML data is read by client and checks the XML

Q5. What are the differences between JSON and XML?

- JSON is known as JavaScript Object Notation which is a light weight data format used to store and send data between systems and very common used in web APIs
- XML is known as extensible Markup Language is markup language used to store and transport data with custom tags
- JSON structure style uses key value pairs like objects and XML structure style uses tags like HTML
- JSON is easier and cleaner to read and XML has more words and symbols to read
- JSON size is smaller file size and XML size is bigger file size because of opening and closing tags
- JSON speed is faster to check and process and XML speed is slower compared to JSON
- JSON supports data types such as String , Number , Boolean , Array , Object and null directly
- XML supports everything in text which needs conversion
- JSON is mostly used in API , web applications , mobile apps , cloud services and XML is used in old systems and configuration files and document formats

---

POSTMAN & Curl :

Q1. What is POSTMAN?

- It is a popular tool used by developers and testers to send HTTP requests to APIs and see the responses easily without writing a full program
- This is an API testing tool which helps you send requests to a server
- You can test GET , POST , PUT , DELETE requests
- This shows the response from the server and no coding is required to test APIs and works with web services and has simple user interface

Q2. How do you use POSTMAN to test APIs?

- API is tested before using them in an application to check if backend service is working
- Sends data to server and see the output and debugs API errors and saves and reuse requests and finally tests authentication and headers
- Can send API requests and add headers like Authorization by sending JSON /XML data
- Can upload files to view server response and measure response time to save request collections

Step by Step : Use Postman to test API :

Step 1 : Open postman :

- Have to install postman app or use web version and click new for HTTP request

Step 2 : Enter API URL :

- Pasting the URL into the bar

Step 3 : Select HTTP Method :

- From dropdown choose method such as :
- To fetch data we use GET and create data using POST and Updating data using PUT and removing data using DELETE

Step 4 : Clicking Send :

- Click send button and response appears

Q3. What is cURL?

- Known as Client URL where it s a command line tool used to send requests to server and get responses from URL such as web address
- This lets you to talk to websites and APIs directly from the terminal or command prompt
- Commonly used by developers , testers and DevOps Engineers
- Also this is used for sending HTTP / HTTPS requests to servers by calling API and downloading files from URLs
- Web services are tested to check API responses to send data to servers and by debugging network requests
- We can use curl in Linux and macOS terminal and Windows command prompt and Power Shell
- Cloud servers such as AWS , EC2 , Ubuntu and also DevOps Environments

Example : (Simple GET request) :

```
curl https://api.github.com
```

- Curl sends a request to GitHub API and server returns JSON response and response is printed in terminal

Example : (Get a Web Page) :

```
curl https://example.com
```

- Downloads and prints the HTML of the webpage

Example : (Downloading a file):

```
curl -o https://example.com/file.zip
```

- **-o** saves file with original name
- File gets downloaded to current folder

Real DevOps Example :

- Test if your server API is working :
- `curl http://localhost:8080/health`
- Response : `{"status":"UP"}` : Confirms your app is running

Q4. How do you use cURL to send HTTP requests?

- Curl is command line tool to send HTTP requests
- Used for calling API and testing web services and downloading files and sending data to servers
- Works in Linux , macOS and Windows such as Power Shell and Git Bash

Working of curl to send HTTP requests :

- GET sends a request by default and prints server response in terminal
- GET request fetches data by default
- POST request is sending data to the server
- POST sends with JSON Data to the server
- PUT request updates the data
- Requested is deleted by DELETE
- Adding headers for authorization , content type and API keys and also adding multiple headers
- Data is send in a form and file is uploaded and file is downloaded
- Response headers are shown by status code , server or content type
- Debug mode is showing full request and response details by requesting and response headers with connection details
- Redirects are followed when we use site to another URL
- HTTPS gives with username and password

Q5. What are the differences between POSTMAN and cURL?

- Postman is a GUI tool known as Graphical User Interface using with buttons and forms
- Mainly used for API testing and development and no need to remember commands and can send HTTPS requests by filling fields like URL , Methods such as GET, POST , PUT , DELETE and headers and body
- It is good for beginners and testers
- Curl is a command line tool and run it using terminal or command prompt or shell
- Using curl we can send HTTP requests by typing commands and used by developers and DevOps Engineers and useful for automation and scripting

Interface :

- Post man has visual interface and like clicking buttons and entering data in boxes and easy to understand
- Curl is text command based with no graphical interface and must type commands manually

Ease of Use :

- Postman is easy for beginners and no need to remember syntax and good for learning API
- Curl requires command knowledge and slightly harder at first and faster once you learn it

Setup :

- Postman must install the postman app which is a heavier software
- Curl is already installed on Linux and macOS and available on Windows can be install easily and very light weight

API Testing Features :

- Postman is built in testing tools and save requests and creates collections and adding test scripts by using the environment variables by the response visualization
- Curl is no built in testing UI and sends request and shows raw output and request does not save unless you script it

Automation :

- Postman automation is possible but needs collections and runner and good for manual and semi-automated testing
- Curl is excellent for automation using bash scripts , CI /CD pipelines and server scripts

Use Cases :

- Use postman when learning API and testing manually and debugging requests and if want visual response view
- Use curl when writing scripts and automating tasks and working on servers using CI /CD pipelines for quick terminal testing

---

HTTP Concepts :

Q1. What is a query parameter?

- It is an extra information that you send in a URL to tell the servers exactly what data you want like adding filters or options to a request
- Also it is a key value pair added at the end of a URL which helps send additional data to the server
- Commonly used in search , filtering and sorting and appears after a question mark (?) in the URL

```
https://shop.com/products?category=shoes
```

- Category is the parameter name and shoes is a parameter value and show only shoes products is what the server understands
- Multiple Query Parameters where you can send more than one parameter using &

```
https://shop.com/products?category=shoes&color=black&size=9
```

- Category is the shoes and colour is black and size is 9
- Server uses all these to filter results

Q2. What is a path variable?

- It is a value that is passed inside the URL path of a web request and used by the server to identify a specific resources
- Like an dynamic part of URL that changes depending on what data you want
- This is a variable inside URL path and helps fetch specific data and changes from request to request commonly used in APIS
- Path variable is used to get specific record like user , product , order and makes URL clean and readable
- Passes important identifiers in the URL itself to avoid sending everywhere in query parameters

`https://example.com/users/101`

- /users are the resource and 101 is path variable and this tells the server give me user with ID = 101

Q3. What is a payload in an HTTP request?

- It means the actual data or content that is sent from the client as browser or app to the server inside the request body
- HTTP request ls like envelope and headers are like address and labels and payload is the message inside the envelope
- The main data you send to the server and usually present in POST , PUT , PATCH requests and stored in the body of the HTTP request
- Tells the server what the data to create or update
- Payload is used when you send data such as From data , Login details , JSON data and XML data and file uploads and API request data
- Payload formats like JSON (which is common) XML , Form data , Plain text and Binay data like files or images
- For ordering food online the URL is the restaurant address and headers are the order type like delivery or pickup and payload is the food order details

Example : HTTP Request with Payload (JSON) :

Request :

```
POST /users HTTP/1.1
Host: example.com
Content-Type: application/json

{
  "name": "Akash",
  "email": "akash@email.com",
  "age": 25
}
```

Explanation :

- POST /users are the request type and path and headers are the metadata and JSON block is the payload where actual data is sent

Q4. What are request headers in HTTP ?

- Small pieces of extra information that a client like a browser of apps sends to a server along with an HTTP request and help the server understand who is making the request and what is being sent and how to respond
- Like a cover note attached to a letter they describe details about the request
- These are key value pairs and send from client to server and provide metadata like information about the request and help server decide how to process the request
- These are important because tells server what data format the client accepts and sends authentication into to provide browser or app details to control caching behaviour specifying content type while managing sessions and cookies

HTTP Request Headers :

Host :

- Tells which server or domain you want and example : `Host: example.com`

User Agent :

- Tells server what browser or app is sending request and example : `User-Agent: Chrome/Windows`

Accept :

- Tells server what response format client can accept an example : `Accept: application/json`

Content Type :

- Tells server what type of data is being sent in request body for example : `Content-Type: application/json`

Authorization :

- Sends login tokens or credentials and used for securing APIs for example : `Authorization: Bearer abc123token`

Cookie :

- Sends stored cookies to server and helps maintain login session and more example : `Cookie: session_id=xyz78`

Accept Language :

- Tells preferred language for example : `Accept-Language: en-IN`

Real Life :

- While ordering food online , the URL is the restaurant address and request body is your food order and request headers are extra instructions like prefer spicy which is accepting header and I am premium member which is authorization header and delivery in English is the accept language

Q5. What are response headers in HTTP?

- Small pieces of information that a server sends back to the browser as client along with response data like HTML , JSON , XML and images
- Give like extra details about the response on how to handle it and what type it is and whether it can secured by rules
- Sent from server to client and comes along with HTTP response and provide metadata like information about the response and help the browser know how to process the data
- This is not visible directly on web page but visible in developer tools

To see Responses Headers :

In Google Chrome or Firefox :

- Open website and right click on inspect and go to network tab and click any request and open headers and see response headers

Response Headers Important :

- Tell browser how to handle data by improving performance and security by managing sessions and cookies to support API communications to handle redirects

Real life :

In a courier package :

- The body is the actual item inside the box and labels on the box is the response headers such as delivery date , sender , type of item

HTTP Response Headers Types :

Content Type :

- It tells what type of data is returned like text/html is the webpage and application/json is the API data and image /png is the image

Content Length :

- The size of the response body in bytes

Cache Control :

- Tells browser whether it should store the response and always ask server again

Set Cookie :

- Server sends cookies to browser which is used for login sessions and tracking and preferences

Location :

- Used when redirecting user to another URL

Server :

- Shows server software info

Date :

- Time when response was generated

Access Control Allow Origin :

- Used in API and allows which websites can access this response

Q6. How do query parameters differ from path variables?

- Path variables are part of the URL path itself and used to identify a specific resource and required to access that resource and represent an ID or unique value when written directly in the URL path
- Query parameters are added at the end of the URL and used to filter , sort , search or modify results which is usually optional and written after a ? and multiple parameters separated by &

Additional Question :

Q1. What is Stateful and stateless communication in web applications ?

- Communication means how a client such as browser or app and server exchange data using requests and responses
- Basically stateful means server remembers past requests and stateless means server does NOT remember past requests

Stateful Communication :

- The server keeps track of user information and previous interactions between requests
- The server remembers who you are and what you did before

Working of Stateful Communication :

- Clients sends a request and server stores session data and in next request server checks stored data and server continues the conversion using stored stat

Example : Real Life : Stateful Communication :

Think of a phone call :

- The call stays connected and both sides remember what was said before and the conversation continues without repeating info

Web Example :

- A shopping cart in a website and login session stored on server and online banking session

Stateless Communication :

- Each request is treated as new and server does not store previous request information
- The server forgets everything after sending the response

Working of Stateless Communication :

- Clients sends request and server processes and responds and server forgets request details and completely new in the next request

Example : Real life : Stateless Communication :

Think of a restaurant counter order :

- You order and get the food and its done and the next order treated as new customer

Web Examples :

- Public Website page requests
